

INNOCENT UNIQUE AKACHUKWU

RUN/CYB/24/17321

CYB 401 ASSIGNMENT

400L

The NVD Entry for CVE-2023-0482 and the Cyber Kill Chain

Analysis of a RESTEasy insecure temporary file vulnerability

Vulnerability Assessments Assignment

1. Introduction

This report discusses the National Vulnerability Database (NVD) entry for CVE-2023-0482, a vulnerability in RESTEasy, and relates it to the stages of the Cyber Kill Chain. The Cyber Kill Chain, developed by Lockheed Martin, traces the seven steps of a cyber-attack so that security teams can identify weaknesses and stop an attack at any stage. The NVD data is useful here because it supplies the severity and technical detail that a defender needs to decide where and how to respond.

2. CVE, NVD and CVSS

Three related terms are used throughout this report:

- **CVE (Common Vulnerabilities and Exposures):** a list of publicly disclosed vulnerabilities maintained by MITRE. Each entry has an ID, dates and a description, but no severity score.
- **NVD (National Vulnerability Database):** a database maintained by NIST that is kept in sync with the CVE list. It adds more detail, including CVSS severity scores, affected products and patch information. The NVD does not create separate IDs; its entries use the CVE ID.
- **CVSS (Common Vulnerability Scoring System):** an open framework for rating the severity of vulnerabilities. Version 3.1 scores range from 0 to 10, with Medium covering 4.0 to 6.9.

3. The NVD Record for CVE-2023-0482

Field	NVD data
Identifier	CVE-2023-0482 (the NVD does not issue its own IDs; it uses the CVE ID)
Source of record	Red Hat (the CVE Numbering Authority that assigned the CVE)
Published in NVD	17 February 2023
Last modified	18 March 2025 (status: Modified)
Description	In RESTEasy, the insecure File.createTempFile() method is used in the DataSourceProvider, FileProvider and Mime4JWorkaround classes. It creates temporary files with insecure permissions that a local user could read.
CVSS v3.1 vector	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
CVSS v3.1 base score	5.5 (Medium)
Sub-scores	Exploitability 1.8, Impact 3.6
Weakness (CWE)	CWE-378 (creation of a temporary file with insecure permissions), assigned by Red Hat. NVD's own classification: NVD-CWE-Other.

Field	NVD data
Affected products (CPE)	Red Hat RESTEasy, for example version 3.15.4. Fixed in RESTEasy 4.7.8.Final.
CISA SSVC assessment	Exploitation: none. Automatable: no. Technical impact: partial.

3.1 CVSS v3.1 breakdown

The NVD vector can be read metric by metric:

Metric	Value	Meaning for this vulnerability
Attack Vector (AV)	Local (L)	The attacker needs local access to the machine, not a network connection.
Attack Complexity (AC)	Low (L)	No special conditions are needed once access exists.
Privileges Required (PR)	Low (L)	A basic user account is enough.
User Interaction (UI)	None (N)	No victim action is needed.
Scope (S)	Unchanged (U)	The impact stays within the vulnerable component's security scope.
Confidentiality (C)	High (H)	Data in the temporary files can be read.
Integrity (I)	None (N)	The flaw does not allow data to be modified.
Availability (A)	None (N)	The flaw does not affect availability.

3.2 A note on the "privilege escalation" classification

The CVSS vector shows that CVE-2023-0482 is a local confidentiality issue: confidentiality impact is High, while integrity and availability are unaffected. It is therefore not a direct privilege escalation. It can contribute to escalation when the leaked files contain credentials, session tokens or other secrets that a lower-privileged user can then use to act with higher privileges. This report treats it as a local information disclosure vulnerability that can enable privilege escalation.

4. Relating the NVD Data to the Cyber Kill Chain

Each field in the NVD record helps explain how the vulnerability could be used at a given stage of an attack, and which controls can stop it.

Stage	What the NVD data shows	Defensive controls
1. Reconnaissance	The CPE list names the affected RESTEasy versions, so public NVD data helps an attacker identify vulnerable targets. Defenders use the same data to find their own exposed assets.	Detect: threat intelligence, web analytics Deny: information sharing policy, hiding version details
2. Weaponization	Exploitability is simple (AC:L), but CISA records no known exploitation and no automation. There is little to build: no malware is needed,	Detect: threat intelligence, NIDS

Stage	What the NVD data shows	Defensive controls
	only a way to find and read the temporary files.	
3. Delivery	AV:L means the attacker needs local access first, for example through phishing, stolen credentials or another compromised application on the same server. This is the main reason the score is only Medium.	Detect: endpoint malware protection Deny: proxy filter, application whitelisting, HIDS
4. Exploitation	PR:L and UI:N mean a low-privileged user can read the temporary files without any victim action. The CWE-378 weakness is the exploitation mechanism.	Deny: patch management (upgrade to 4.7.8.Final or later), secure umask and permissions Detect: HIDS, file integrity monitoring Contain: trust zones
5. Installation	Integrity impact is "None", so the flaw cannot plant or modify anything by itself. Persistence would come from credentials or tokens stolen from the files.	Deny: privilege separation, strong passwords, two-factor authentication Detect: SIEM, HIDS
6. Command and control	Stolen secrets could give the attacker more privileged access. This is how the flaw can contribute to privilege escalation and maintained access.	Deny: network segmentation Detect: NIDS, HIDS Contain: trust zones
7. Actions on objectives	C:H describes the final harm: exposure of confidential data.	Deny: data-at-rest encryption Detect/Disrupt: DLP, SIEM Contain: incident response

5. Related Frameworks

- **STRIDE:** Information disclosure (a violation of confidentiality), with Elevation of privilege as a possible follow-on effect.
- **OWASP Top 10 (2021):** A06 Vulnerable and Outdated Components, and A05 Security Misconfiguration (insecure default permissions).
- **MITRE ATT&CK:** Relevant to the Credential Access, Collection and Privilege Escalation tactics.

6. Use of NVD Data in the Vulnerability Management Lifecycle

- **Discover:** use the NVD's affected product list to find assets and applications that include RESTEasy.
- **Assess:** scan with a tool such as Qualys or Nessus, or a dependency scanner such as OWASP Dependency-Check, which rely on NVD data.
- **Prioritize:** the CVSS base score of 5.5 (Medium) and the criticality of the affected asset set the priority.

- **Remediate:** upgrade RESTEasy to a fixed version. For a Medium vulnerability on a public-facing asset, the SLA in the course material is under 30 days.
- **Verify:** rescan to confirm the vulnerable version is gone.

7. Mitigation and Recommendations

- Upgrade RESTEasy to version 4.7.8.Final or later, or to a current 6.x release.
- Check transitive dependencies, since many projects include RESTEasy indirectly (for example through resteasy-multipart-provider).
- Restrict access to the temporary directory, or set a stricter umask for the service account.
- Apply privilege separation and avoid running applications of different trust levels on one shared host.
- Deploy host-based intrusion detection and file integrity monitoring, and forward logs to a SIEM.

8. Conclusion

The NVD entry for CVE-2023-0482 turns a short CVE description into usable risk information: a Medium CVSS score of 5.5, a local attack vector, a high confidentiality impact, a specific weakness type and a list of affected versions. Read against the Cyber Kill Chain, this shows a flaw that matters mainly after an attacker already has a foothold, at the Exploitation, Installation, Command and Control, and Actions on Objectives stages. The strongest defence is to break the chain early by patching the dependency, hardening permissions and limiting local access, supported by layered detection controls such as HIDS, file integrity monitoring and a SIEM.

References

- National Vulnerability Database (NVD), NIST. Entry for CVE-2023-0482.
- CVE Program record for CVE-2023-0482 (published by Red Hat, February 2023).
- Course material: Vulnerabilities assessments - introduction (CVE, NVD, CVSS, Cyber Kill Chain, STRIDE, OWASP Top 10).